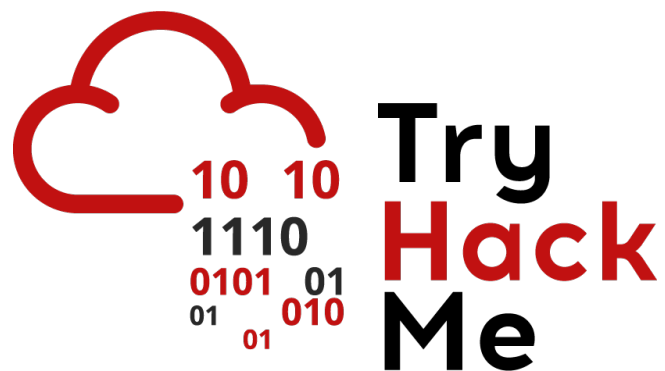




Informe Técnico

Maquina: Lo-Fi



Este documento es confidencial y contiene información sensible.
No debería ser impreso o compartido con terceras entidades

18 de Enero de 2025



Índice

1. Antecedentes	2
2. Objetivo	2
2.1. Alcance	3
2.2. Impedimentos y limitaciones	3
2.3. Resumen general	3
3. Reconocimiento	4
3.1. Enumeración de servicios expuestos	4
3.2. Enumeración de servidores web	5
4. Identificación y explotación de vulnerabilidades	6
4.1. Explotación del Local File Inclusion	6
5. Contramedidas y buenas practicas	8
5.1. Vulnerabilidad LFI	8
6. Conclusión	8



1. Antecedentes

El presente documento recoge los resultados obtenidos durante la fase de auditoría realizada a la maquina **Lo-Fi**, enumerando todos los vectores de ataques encontrados, así como la explotación realizada para cada uno de estos.

Esta maquina ha sido usada desde la plataforma **TryHackMe**, una plataforma de entrenamiento y práctica para personas interesadas en la seguridad informática y en el hacking ético.

A continuación, se proporciona el enlace directo a la máquina:

Dirección URL

<https://tryhackme.com/r/room/lofi>

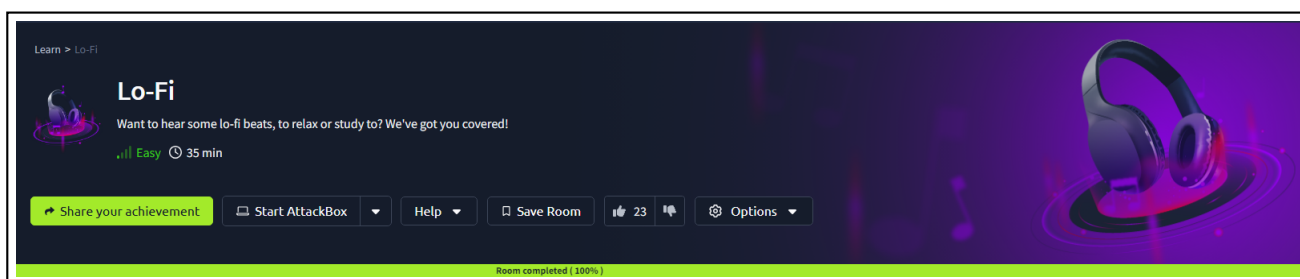


Imagen 1: Pagina principal del servicio web que proporciona la maquina

2. Objetivo

Los objetivos de la presente auditoria se enfocan en la identificación de posibles vulnerabilidades y debilidades en la maquina **Lo-Fi**, con el propósito de garantizar la integridad y confidencialidad de la información almacenada en ella.

Con este fin se ha llevado acabo un análisis exhaustivo de todos los servicios detectados que se encontraban en dicho servidor, recopilando información detallada de aquellos que representan un riesgo potencial desde el punto de vista de la seguridad informática.



2.1. Alcance

A continuación, se representan los objetivos a cumplir para esta auditoría:

- Identificar los puertos y servicios vulnerables
- Realizar una explotación de las vulnerabilidades encontradas
- Conseguir acceso al servidor mediante la explotación de los servicios vulnerables identificados
- Enumerar vías potenciales de elevar privilegios en el sistema una vez este ha sido vulnerado

2.2. Impedimentos y limitaciones

Durante el proceso de auditoría, está terminantemente prohibido realizar algunas de las siguientes actividades:

- Realizar tareas que puedan ocasionar una **denegación de servicios** o afectar a la disponibilidad de los servicios expuestos
- Borrar archivos residentes en el servidor una vez este haya sido vulnerado

2.3. Resumen general

A continuación, se presenta un resumen de los hallazgos obtenidos durante la fase de enumeración de puertos y servicios:

Iniciamos el proceso con una exhaustiva enumeración de los puertos y servicios disponibles en la máquina objetivo. Como resultado de esta actividad, se identificaron dos puertos abiertos: el **puerto 80**, correspondiente al servicio web, y el **puerto 22**, utilizado para conexiones SSH.

Al acceder al servicio web desplegado en la máquina, se detectó una posible vulnerabilidad de **Local File Inclusion (LFI)**. Tras realizar las pruebas pertinentes, se constató que esta vulnerabilidad presenta un nivel de riesgo significativo y es susceptible de ser explotada con relativa facilidad, principalmente debido a la falta de sanitización adecuada en las entradas del sistema.

Este hallazgo resalta la necesidad de implementar medidas de seguridad adicionales para mitigar los riesgos asociados a esta vulnerabilidad.



3. Reconocimiento

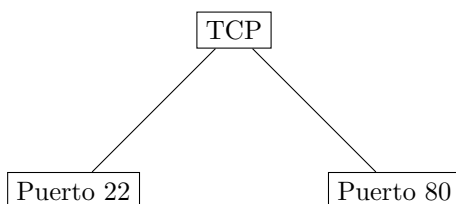
3.1. Enumeración de servicios expuestos

A continuación, se adjunta una evidencia de los puertos y servicios identificados durante el reconocimiento aplicado con la herramienta **nmap**:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 9c:fb:b6:9b:3b:7b:27:be:b8:61:27:59:91:6f:0e:8d (RSA)
|_   256 c3:7c:a9:31:21:14:b1:ea:64:fb:af:6d:d6:e0:73:be (ECDSA)
|_   256 9f:8e:97:39:87:7f:67:a1:de:08:b7:97:39:d9:25:f0 (ED25519)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Lo-Fi Music
|_ http-server-header: Apache/2.2.22 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Imagen 2: Enumeración de puertos con nmap

En este caso, se identificaron 2 puertos activos corriendo por el protocolo TCP:



Asimismo, no se encontraron puertos expuestos a través de otros protocolos, por lo que se priorizará la evaluación de los puertos identificados en el primer escaneo efectuado.



3.2. Enumeración de servidores web

A continuación, se representan los resultados obtenidos con la herramienta **whatweb**, una herramienta de reconocimiento web que se utiliza para identificar tecnologías web específicas que se emplean en un sitio web, tras aplicar un reconocimiento sobre el servicio HTTP corriendo en el puerto 80:

```
> whatweb 10.10.248.35
http://10.10.248.35 [200 OK] Apache[2.2.22], Bootstrap[4.5.0], Country[RESERVED][ZZ], Frame, HTML5, HTTPServer
[Ubuntu Linux][Apache/2.2.22 (Ubuntu)], IP[10.10.248.35], Title[Lo-Fi Music], YouTube
```

Imagen 3: Enumeración del servicio HTTP por el puerto 80

En los resultados obtenidos, es posible identificar las versiones para algunas de las tecnologías existentes

Tecnología	Versión
Apache	2.2.22
Bootstrap	4.5.0

Después de realizar una indagación exhaustiva en el servicio web, se ha observado que, con excepción de la página principal, todas las demás páginas están siendo incluidas mediante código PHP. Este comportamiento permite la modificación de la URL, lo que sugiere la presencia de una vulnerabilidad de tipo **Local File Inclusion (LFI)**.

Una vulnerabilidad de Local File Inclusion es un tipo de vulnerabilidad que permite mostrar y acceder a archivos locales del sistema a los cuales no se debería tener acceso.

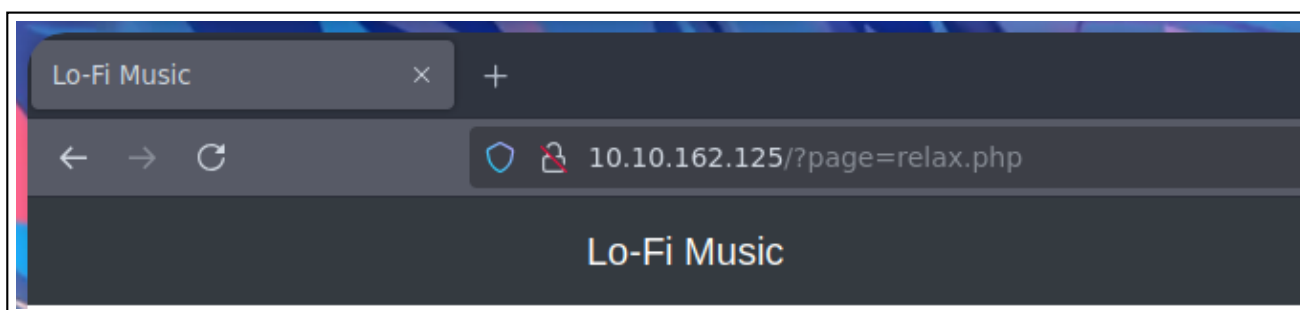


Imagen 4: Posible LFI mediante la URL del servidor web



4. Identificación y explotación de vulnerabilidades

4.1. Explotación del Local File Inclusion

Durante la fase de reconocimiento, al explorar el servicio web, se identificó una URL que podía ser susceptible a una vulnerabilidad de **Local File Inclusion (LFI)**. Gracias a esta observación, se llevaron a cabo diversas pruebas de ataque sobre dicha vulnerabilidad. Sin embargo, al intentar ejecutar algunos de estos ataques, se recibió un mensaje del servidor en lugar de la información restringida. Esto podría indicar que la vulnerabilidad ha sido contemplada y que se han implementado medidas de sanitización adecuadas.

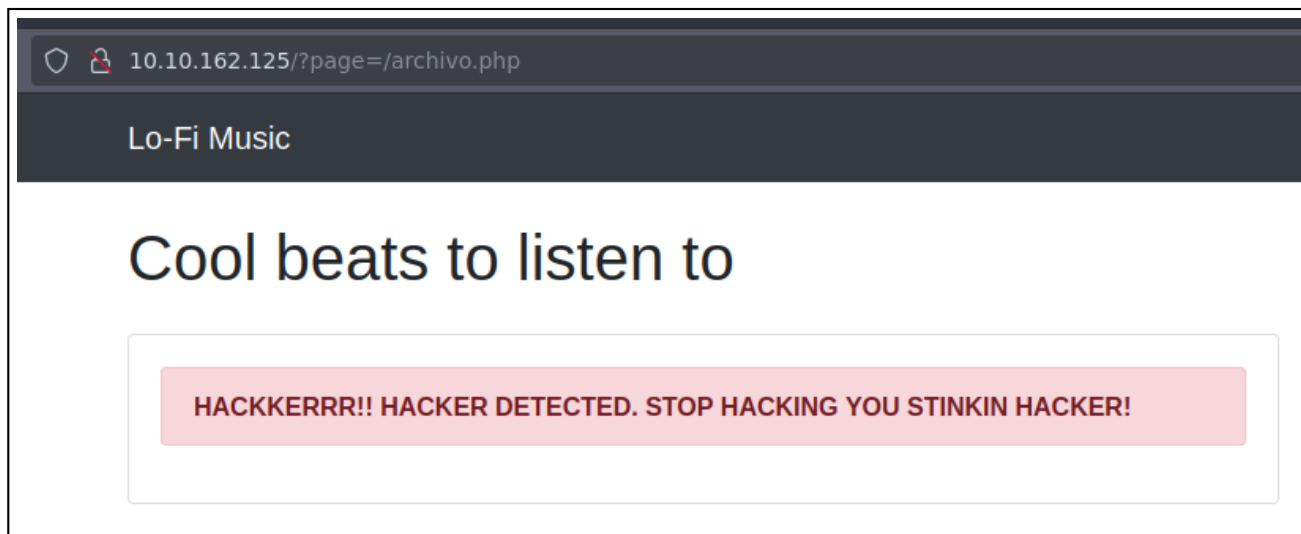


Imagen 5: Mensaje del servidor al intento de ataque LFI

Aunque, a raíz del mensaje anterior, podríamos pensar que la vulnerabilidad estaba correctamente sanitizada, al combinar este ataque con la técnica de **path traversal**, se puede obtener una perspectiva diferente. La técnica de path traversal permite navegar de vuelta a la raíz del servidor, proporcionando un punto de partida más claro para buscar archivos restringidos. Al aplicar esta técnica, se observa que, en lugar de recibir el mensaje de error, se muestra el archivo correspondiente. Esto indica que, efectivamente, el servidor es **vulnerable a Local File Inclusion (LFI)**.

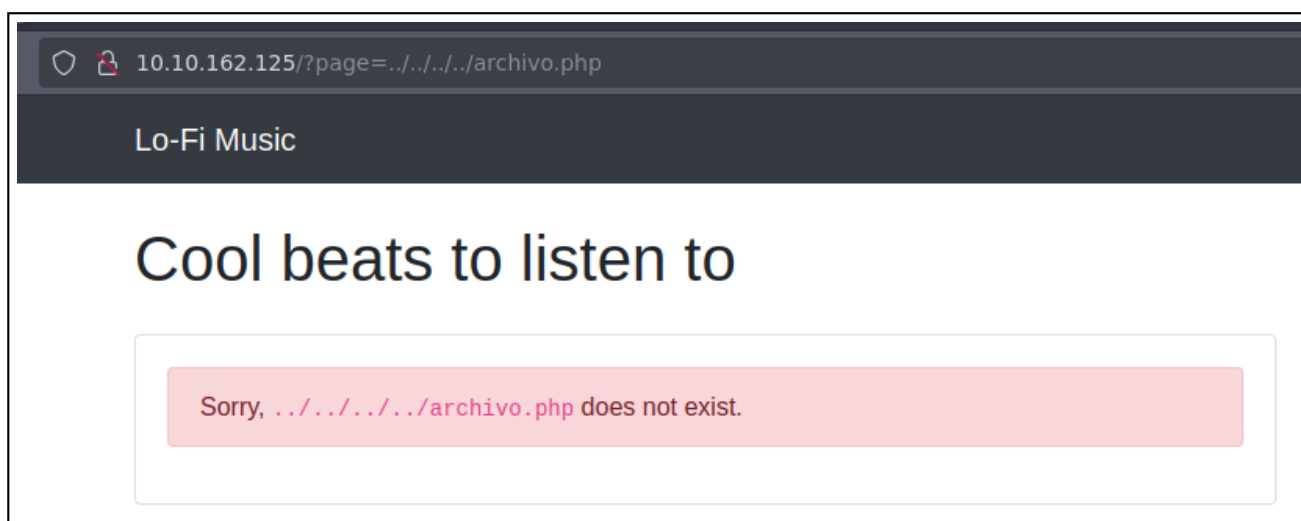


Imagen 6: Respuesta del servidor validando el Local File Inclusion



Esto hace posible la obtención de información y/o archivos restringidos, como podría ser el caso del archivo `/etc/passwd`. Este archivo es crucial, ya que almacena todos los usuarios del sistema junto con sus terminales correspondientes, pudiendo incluir información sensible.

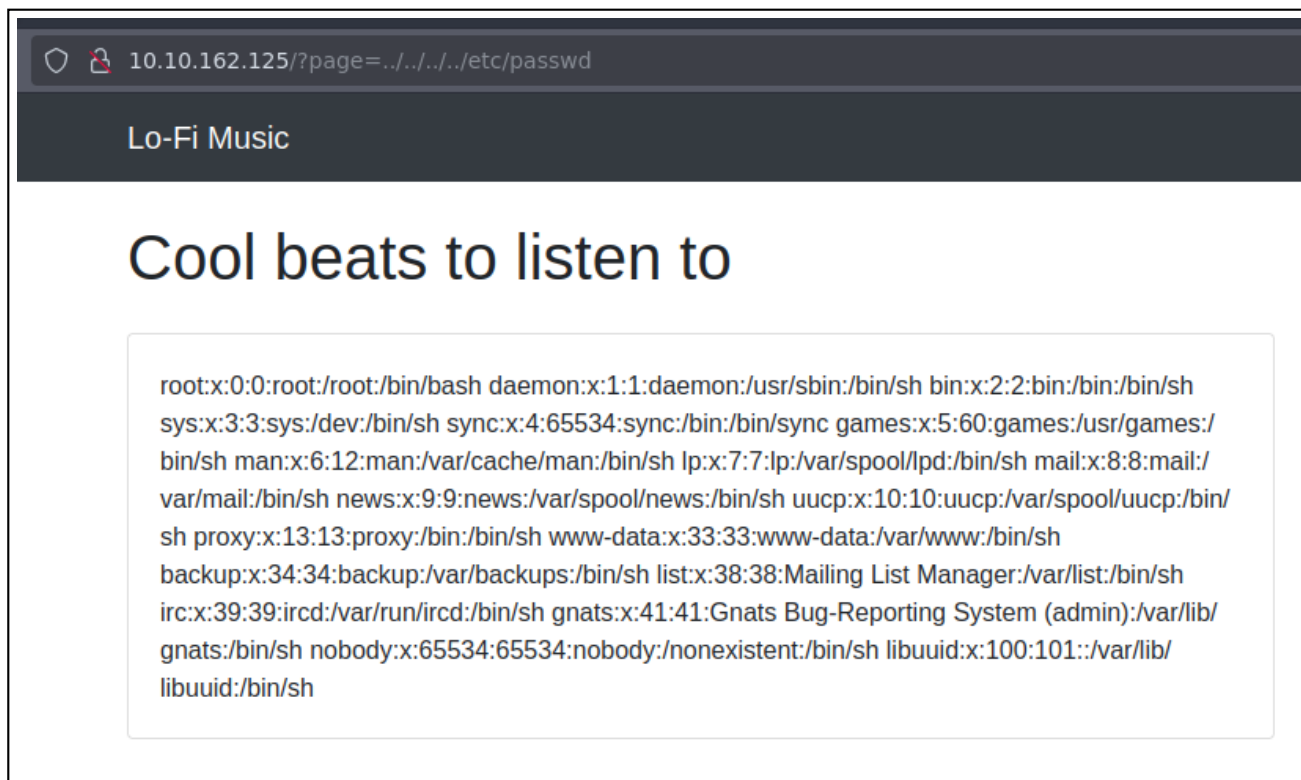


Imagen 7: Información sensible correspondiente a `/etc/passwd`

Además de la información previamente mencionada, es posible obtener información confidencial del archivo `flag.txt` mediante el uso de esta misma técnica y ataque al servidor web.

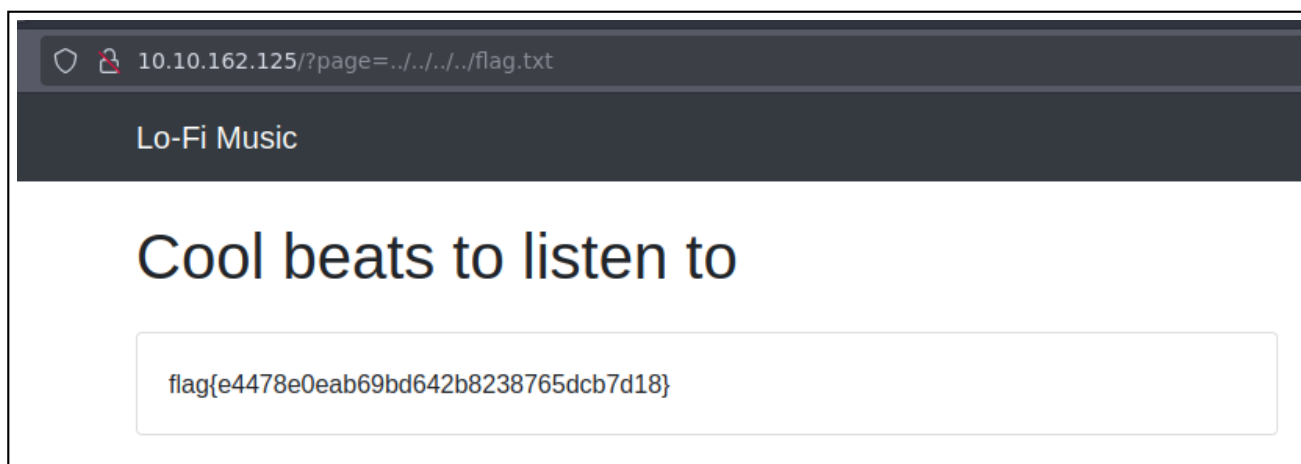


Imagen 8: Información sensible correspondiente al archivo `Flag.txt`



5. Contramedidas y buenas practicas

Con el objetivo de evitar posibles explotaciones indeseadas en el servidor expuesto, se enumeran a continuación las buenas prácticas a llevar a cabo para las diferentes vulnerabilidades descubiertas.

5.1. Vulnerabilidad LFI

Como se mencionó anteriormente, se debería aplicar una mayor sanitización al verificar el parámetro recibido desde la URL. Esto incluye prohibir el uso del **carácter** /, tanto en su formato normal como en su representación hexadecimal o URL codificada.

A modo de resumen, se presentan las URL afectadas por esta vulnerabilidad. Estas son las URL que deberían ser sanitizadas o que son vulnerables a este tipo de ataque. Aunque la URL base es la misma, se refieren a los diferentes **endpoints** que proporciona el propio servicio web.

- `http://10.10.162.125/?page=relax.php`
- `http://10.10.162.125/?page=sleep.php`
- `http://10.10.162.125/?page=chill.php`
- `http://10.10.162.125/?page=coffee.php`
- `http://10.10.162.125/?page=vibe.php`
- `http://10.10.162.125/?page=game.php`

6. Conclusión

Se han detectado **vulnerabilidades críticas** que pueden suponer un riesgo desde el punto de vista de la seguridad informática. Han sido encontradas vulnerabilidades las cuales permitieron la obtención de archivos sensibles y/o privilegiados, como `"/etc/passwd"`, `"flag.txt"`.

Esto ha sido posible debido a una mala sanitización realizada en las URLs del servicio web expuesto

Se recomienda encarecidamente aplicar las contramedidas recomendadas para corregir estas vulnerabilidades lo antes posible, dado que de lo contrario se podría comprometer la seguridad informática del servidor y poner en riesgo la integridad de todos los datos almacenados en este.